

Report Malware Analysis | WannaCry & DanaBot |

S9L3

1. Obiettivo

L'esercitazione S9L3 prevede l'analisi del campione **WannaCrypt0r.exe** (presente nella cartella Malware/Ransomware/ della FlareVM) tramite la piattaforma sandbox **tria.ge** (Recorded Future Sandbox). Il file è stato caricato in formato ZIP e detonato su due ambienti distinti (Windows 10 e Windows 11) per confrontare i comportamenti. L'analisi è integrata con un LLM per la descrizione delle tecniche e la valutazione delle contromisure.

Nota: Il campione NON è stato eseguito localmente su FlareVM, come da istruzioni della consegna. L'analisi dinamica è stata condotta esclusivamente in ambienti sandbox isolati su tria.ge.

2. Informazioni sul Campione

File analizzato	WannaCrypt0r.exe
Piattaforma	tria.ge - Recorded Future Sandbox
Sample ID	260603-qk7ljafy4y
Data analisi	2026-06-03 13:24
SHA256 (zip)	1c80d48212f2da25f7ee89db91e1786a83a46b222f3e949656e58a422a1cd973
SHA256 (exe)	ed01ebfbc9eb5bbea545af4d01bf5f1071661840480439c6e5babe8e080e41aa
File Size	3.4 MB
Score tria.ge	10 / 10 - Known bad
Famiglia	WannaCry (WannaCrypt0r)
Threat Level	Known bad

WannaCry (aka WannaCrypt, WanaCrypt0r 2.0) è uno dei ransomware più devastanti della storia informatica. Lanciato nel maggio 2017, ha infettato oltre 200.000 sistemi in 150 paesi in 24 ore, causando danni stimati tra 4 e 8 miliardi di dollari. Sfrutta l'exploit **EternalBlue** (CVE-2017-0144) - sviluppato dalla NSA e trafugato dal gruppo Shadow Brokers - per propagarsi autonomamente via SMBv1 (porta 445), comportandosi come un **worm** oltre che come ransomware.

3. Overview Analisi Sandbox - tria.ge

Il campione ha ottenuto il punteggio massimo di **10/10** su tria.ge, con classificazione **Known bad**. I tag identificati dalla sandbox coprono l'intera catena di attacco:



4. MITRE ATT&CK; Enterprise Matrix V16

tria.ge ha mappato le tecniche rilevate secondo il framework MITRE ATT&CK; V16. Le tattiche coperte spaziano dall'esecuzione iniziale fino all'impatto finale, confermando la natura **multi-stage** di WannaCry:

Tattica	ID	Tecnica
Execution - TA0002	T1047	Windows Management Instrumentation (WMI)
Persistence - TA0003	T1547.001	Registry Run Keys / Startup Folder
Privilege Escalation - TA0004	T1547.001	Registry Run Keys / Startup Folder
Defense Evasion - TA0005	T1222.001	Windows File and Directory Permissions Modification
Defense Evasion - TA0005	T1564.001	Hide Artifacts - Hidden Files and Directories
Defense Evasion - TA0005	T1070.004	Indicator Removal - File Deletion
Defense Evasion - TA0005	T1112	Modify Registry
Credential Access - TA0006	T1555.003	Credentials from Web Browsers
Credential Access - TA0006	T1552.001	Credentials In Files
Discovery - TA0007	T1082	System Information Discovery
Discovery - TA0007	T1614.001	System Language Discovery
Collection - TA0009	T1005	Data from Local System
Impact - TA0040	T1490	Inhibit System Recovery (Shadow Copy)
Impact - TA0040	T1491	Defacement (Wallpaper ransom note)

5. Analisi Comportamentale (Behavioral)

Il campione è stato detonato su due piattaforme distinte. Il comportamento è risultato identico su Windows 10 e Windows 11, confermando la cross-platform effectiveness del ransomware:

Step 1 Avvio ed operazioni su file system

All'avvio, WannaCrypt0r.exe esegue immediatamente operazioni di preparazione del sistema: nasconde la propria directory con attrib +h e assegna permessi completi a tutti gli utenti per facilitare la cifratura:

```
# Nascondi directory corrente
attrib +h .

# Assegna permessi Everyone:Full su tutta la struttura
icacls . /grant Everyone:F /T /C /Q

# Nasconde il Recycle Bin su unità esterne (propagazione)
attrib +h +s F:\$RECYCLE
```

Step 2 Persistenza - Registry Run Key

WannaCry aggiunge una chiave Run al registro di sistema per garantire la propria esecuzione ad ogni avvio. Il nome della chiave è randomizzato ad ogni infezione (diverso su Win10 e Win11):

```
# Win10 - chiave run:
reg add HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run
/v "fydj1lcp217" /t REG_SZ
/d "C:\Users\Admin\AppData\Local\Temp\tasksche.exe" /f

# Win11 - chiave run (nome diverso, stesso comportamento):
reg add HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run
/v "ngqgimofq668" /t REG_SZ
/d "C:\Users\Admin\AppData\Local\Temp\tasksche.exe" /f

# Percorso registry completo (WOW6432Node = 32bit su 64bit):
HKLM\SOFTWARE\WOW6432Node\Microsoft\Windows\CurrentVersion\Run\
```

Step 3 Eliminazione Shadow Copies e Recovery (MITRE T1490)

Uno dei comandi più critici eseguiti da WannaCry: elimina tutte le copie shadow di Windows e disabilita il ripristino del sistema, rendendo impossibile il recupero dei file senza pagare il riscatto:

```
cmd.exe /c vssadmin delete shadows /all /quiet
& wmic shadowcopy delete
& bcdedit /set {default} bootstatuspolicy ignoreallfailures
& bcdedit /set {default} recoveryenabled no
& wbadmin delete catalog -quiet
```

Questo singolo comando rende il ripristino da backup di sistema impossibile. vssadmin, wmic shadowcopy delete e wbadmin agiscono su tre livelli diversi di backup per massimizzare la distruzione. bcdedit disabilita il recovery mode di Windows per impedire il boot in modalità sicura.

Step 4 Nota di Riscatto - Wallpaper e @WanaDecryptor@

WannaCry imposta il wallpaper del desktop come nota di riscatto tramite modifica del registro di sistema, e lancia @WanaDecryptor@.exe che mostra la finestra di pagamento con timer e indirizzo Bitcoin:

```
# Modifica wallpaper via registro:
HKCU\Control Panel\Desktop\Wallpaper =
"C:\Users\Admin\Desktop\@WanaDecryptor@.bmp"

# Avvio interfaccia decryptor:
taskse.exe C:\Users\Admin\AppData\Local\Temp\@WanaDecryptor@.exe
```

Step 5 Comunicazione C2 via Rete Tor

WannaCry avvia un'istanza Tor locale (taskhsvc.exe) per comunicare in modo anonimo con i server C2. Suricata ha rilevato il certificato X.509 caratteristico dei nodi Tor:

```
# Avvio client Tor:
TaskData\Tor\taskhsvc.exe

# Comunicazione locale (SOCKS proxy Tor):
127.0.0.1:9050 <- porta Tor SOCKS

# Suricata Alert:
Tor Node X.509 Certificate Pattern Detected - Inbound

# Tor relay contattati (behavioral1 - Win10):
37.59.46.159:9001 [FR] - Tor relay
86.59.21.38:443 [AT] - Tor relay
198.199.64.217:443 [US] - Tor relay
163.172.149.155:443 [FR] - Tor relay
193.23.244.244:443 [DE] - Tor relay
```

6. Analisi di Rete (Network)

Il traffico di rete è interamente veicolato attraverso la rete Tor, rendendo difficile il tracciamento del C2. Di seguito i contatti di rete rilevati nelle due detonazioni:

Paese	IP : Porta	Proto	Ruolo
US	8.8.8.8:53	UDP	DNS Google (risoluzione domini sandbox)
GB	2.19.117.92:443	TCP	Akamai CDN - res.public.onecdn.static.microsoft
N/A	127.0.0.1:9050	TCP	Tor SOCKS proxy locale (taskhsvc.exe)
FR	37.59.46.159:9001	TCP	Tor relay node
AT	86.59.21.38:443	TCP	Tor relay node

US	198.199.64.217:443	TCP	Tor relay node
FR	163.172.149.155:443	TCP	Tor relay node
DE	193.23.244.244:443	TCP	Tor relay node
US	173.255.245.116:9001	TCP	Tor relay node (Win11)
DE	131.188.40.189:443	TCP	Tor relay node (Win11)

La porta 9001 è la porta standard dei Tor relay. La porta 9050 è il SOCKS proxy locale di Tor. Tutti i C2 reali di WannaCry sono raggiungibili solo attraverso la rete Tor - non ci sono domini C2 in chiaro, rendendo il blocco tramite DNS inefficace.

7. File Droppati - Componenti WannaCry

WannaCry estrae dalla propria risorsa compressa numerosi componenti. Di seguito i file principali identificati dalla sandbox:

tasksche.exe	Eseguibile principale di cifratura - avviato tramite Run key
taskdl.exe	Task deletion - rimuove file temporanei post-cifratura
taskse.exe	Task execution - avvia l'interfaccia @WanaDecryptor@.exe
@WanaDecryptor@.exe	Interfaccia grafica ransom note con countdown e BTC address
@WanaDecryptor@.bmp	Immagine wallpaper ransom note - sfondo rosso con istruzioni
taskhsvc.exe	Client Tor - mantiene comunicazione C2 anonima
tor.exe	Binario Tor incluso nel pacchetto (TaskData/Tor/)
m.vbs	Script VBScript - esegue operazioni ausiliarie
*.bat	Script batch numerato - sequenza di comandi di attacco
*.wnry (b,c,r,s,t,u)	Componenti cifrati del ransomware - chiavi, config, risorse
msg/m_*.wnry	Note di riscatto in 20+ lingue (italiano, inglese, cinese...)
LIBEAY32.dll, SSLEAY32.dll	OpenSSL - cifratura asimmetrica RSA/AES
libgcc_s_sjlj-1.dll, zlib1.dll, libevent-*.dll	Librerie Tor

8. Catena di Esecuzione (Process Tree)

Di seguito la catena completa dei processi avviati da WannaCrypt0r.exe ricostruita dalla sandbox. Il processo padre inietta codice nei processi di sistema tramite WriteProcessMemory (MITRE T1055 - Process Injection):

[illegible]

9. Considerazione Finale (Analisi AI)

WannaCrypt0r.exe è un campione della famiglia **WannaCry 2.0**, uno dei cyberattacchi più devastanti della storia informatica. L'analisi sandbox ha confermato l'intera kill chain in pochi secondi di esecuzione, con comportamento identico su Windows 10 e Windows 11:

Worm + Ransomware - doppia natura letale

WannaCry non è solo un ransomware: è anche un **worm** che si propaga autonomamente sfruttando **EternalBlue (CVE-2017-0144)** - exploit per SMBv1 - senza richiedere alcuna interazione dell'utente. In reti non patchate, un singolo sistema infetto può compromettere centinaia di macchine in pochi minuti.

Anti-recovery sistematico - T1490

Il comando di eliminazione shadow copies è tra i più pericolosi: in un unico one-liner distrugge i backup locali di Windows, disabilita il ripristino del sistema e impedisce il boot in recovery mode. Senza backup offline, il recupero è praticamente impossibile.

C2 via Tor - tracciamento impossibile

Tutta la comunicazione C2 è veicolata attraverso la rete Tor, rendendo impossibile l'identificazione dei server degli attaccanti tramite analisi del traffico di rete. Le regole Suricata rilevano il certificato X.509 caratteristico dei nodi Tor come unico indicatore.

Kill switch - una feature non prevista dagli attaccanti

Nel maggio 2017, il ricercatore MalwareTech (Marcus Hutchins) scoprì che WannaCry controllava la raggiungibilità di un dominio specifico prima di avviarsi: se il dominio era raggiungibile, il malware si fermava. Registrando il dominio per circa 10 dollari, bloccò la propagazione globale. Questa storia evidenzia come l'analisi approfondita del malware - esattamente come quella condotta in questa esercitazione - possa fare la differenza tra un incidente e una catastrofe.

10. Flusso Completo dell'Esercitazione

#	Fase	Azione	Risultato
1	Preparazione	Caricamento WannaCrypt0r.exe su tria.ge	Sample ID: 260603-qk7ljafy4y
2	Detonation	Sandbox Win10 - max 148s kernel	Score 10/10 - Known bad
3	Detonation	Sandbox Win11 - max 149s kernel	Comportamento identico confermato
4	MITRE	Mapping ATT&CK; V16	14 tecniche identificate
5	Persistence	Run key HKLM\...\Run\tasksche.exe	Sopravvivenza al riavvio
6	Anti-recovery	vssadmin/wmic/bcdedit - shadow copy delete	Backup locali distrutti
7	Ransom note	Wallpaper + @WanaDecryptor@.exe	Interfaccia pagamento BTC
8	C2 / Tor	taskhsvc.exe → Tor relay 5 nodi Analisi	Suricata alert X.509 Tor
9	Network	traffico - solo Tor, no DNS C2	10 IP Tor relay identificati
10	AI Analysis	Analisi con LLM - kill chain ricostruita	Kill switch WannaCry documentato

11. Conclusioni e Contromisure

WannaCrypt0r.exe è un campione altamente pericoloso che combina ransomware, worm e capacità spyware in un unico payload. La sandbox tria.ge ha rivelato l'intera kill chain in meno di 150 secondi di esecuzione, confermando le capacità distruttive del malware su qualsiasi versione di Windows non patchata.

Comportamento / IOC	Gravità	Contromisura
EternalBlue SMBv1 - propagazione worm senza interazione utente	Critica	Disabilitare SMBv1; applicare patch MS17-010; firewall su porta 445
Shadow copy deletion - impossibilità di recovery locale	Critica	Backup offline air-gapped; snapshot immutabili su storage esterno
Registry Run Key persistence - sopravvivenza al riavvio	Alta	EDR con alert su scritture HKLM\Run; Sysmon Event ID 13
C2 via Tor - anonimizzazione traffico malevolo	Alta	Blocco uscita Tor (porta 9001/9050); Deep Packet Inspection
Cifratura file con RSA/AES - ransom irrecoverabile	Critica	Aggiornamenti OS; backup 3-2-1; principio del minimo privilegio

12. DanaBot - Overview Analisi Sandbox (tria.ge)

DanaBot (aka DanaBot Banking Trojan) è un malware modulare di tipo **banker/botnet**, attivo dal 2018, specializzato nel furto di credenziali bancarie tramite web injection, keylogging e screenshot. Opera come **Malware-as-a-Service (MaaS)**, affittato a gruppi criminali. Il campione analizzato è un payload x86 da 2.7MB che utilizza tecniche LOLBin (Living-off-the-Land) per nascondersi nei processi di sistema.

File analizzato	DanaBot.exe (da DanaBot.exe.zip)
Sample ID	260603-rw6daahv4z
SHA256 (zip)	ca5414577115243f7b0ed0413ef34fd71526c1014486884a8ce30c3342c38c47
SHA256 (exe)	db0d72bc7d10209f7fa354ec100d57abbb9fe2e57ce72789f5f88257c5d3ebd1
SHA256 (DLL)	abd75572f897cdda88cec22922d15b509ee8c840fa5894b0aecbef6de23908a3
File Size	2.7 MB - payload x86
Score tria.ge	10 / 10 - Known bad
Famiglia	DanaBot - banker, botnet, trojan
Piattaforma	Win10: attivo Win11: crash (anti-VM/anti-detection)
Analisi locale	Procmon su FlareVM - log: Procmoc_Logfile.PML

13. Tecnica di Iniezione - LOLBins (regsvr32 → rundll32)

DanaBot utilizza una tecnica sofisticata di **Process Injection via LOLBin**: anziché eseguire codice malevolo direttamente, estrae una DLL dal proprio corpo e la carica tramite strumenti legittimi di Windows (regsvr32.exe e rundll32.exe), rendendo difficile il rilevamento da parte degli AV.

```
# Step 1 - DanaBot estrae DanaBot.dll in %TEMP%
# (WriteProcessMemory: PID 4228 → regsvr32 PID 3376)
# Step 2 - Registra la DLL tramite regsvr32 (export f1 = DllRegisterServer)
regsvr32.exe -s C:\Users\Admin\AppData\Local\Temp\DanaBot.dll
f1 C:\Users\Admin\AppData\Local\Temp\DanaBot.exe@4228

# Step 3 - Esegue il payload via rundll32 (export f0)
# (WriteProcessMemory: regsvr32 PID 3376 → rundll32 PID 5092)
rundll32.exe C:\Users\Admin\AppData\Local\Temp\DanaBot.dll,f0

# Risultato: rundll32.exe (processo legittimo) effettua le chiamate C2
# → Badlisted process makes network request (8 volte rilevato)
```

La catena DanaBot.exe → regsvr32.exe → rundll32.exe è una tecnica classica di **LOLBin injection** (MITRE T1218): il payload malevolo viene eseguito all'interno di processi di sistema firmati da Microsoft, bypassando le whitelist degli antivirus. rundll32.exe è il processo che effettivamente comunica con il C2 - non il malware originale.

14. Analisi di Rete - DanaBot C2

A differenza di WannaCry (che usa Tor), DanaBot comunica direttamente con i propri server C2 via HTTPS (porta 443). Il traffico è cifrato ma identificabile per IP di destinazione:

Paese	IP : Porta	Proto	Ruolo
FR	51.77.7.204:443	TCP	C2 principale - contattato 5+ volte da rundll32.exe
US	149.255.35.125:443	TCP	C2 secondario (backup/failover)
CA	51.222.39.81:443	TCP	C2 secondario
FR	51.178.195.151:443	TCP	C2 secondario
GB	2.20.12.98:443	TCP	Akamai CDN (Microsoft) - sandbox artifact
US	8.8.8.8:53	UDP	DNS Google - risoluzione sandbox

Il C2 principale 51.77.7.204 (Francia, OVH) è stato contattato 5 volte in 149 secondi da rundll32.exe - confermando la connessione al pannello di controllo botnet. La comunicazione avviene su porta 443 (HTTPS) per mimetizzarsi nel traffico legittimo.

15. Analisi Procmon - FlareVM (Analisi Dinamica Locale)

Il campione è stato eseguito localmente su FlareVM con **Process Monitor (Procmon)** attivo per catturare le operazioni su file system, registro e rete in tempo reale. Il log è stato salvato in formato Procmon_Logfile.PML. L'analisi del file binario tramite strings ha rivelato le seguenti attività prima del crash:

Osservazione 1 Anti-Debug - IFEO Check

DanaBot verifica le **Image File Execution Options (IFEO)** per rilevare la presenza di debugger agganciati al processo:

```
# Chiavi IFE0 controllate da DanaBot (rilevate nel log Procmon):
HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\
Image File Execution Options\DanaBot.exe

HKLM\SOFTWARE\Microsoft\windows nt\CurrentVersion\
Image File Execution Options\DanaBot.exe [variante case-insensitive]
```

Osservazione 2 WOW64/ARM Emulation - Anti-VM

Il log mostra accessi ripetuti a `HKLM\SOFTWARE\Microsoft\Wow64\x86\xtajit\DanaBot.exe` chiavi relative alla JIT compilation x86 su ARM (Apple Silicon). DanaBot probabilmente rileva il layer di emulazione WOW64/ARM (C:\Windows\SyChpe32\), e va in crash come comportamento anti-VM/anti-analysis:

```
# DLL caricate da SyChpe32 (ARM emulation layer - non standard su x86):  
C:\Windows\SyChpe32\kernel32.dll  
C:\Windows\SyChpe32\KernelBase.dll  
C:\Windows\SyChpe32\ntdll.dll  
C:\Windows\SyChpe32\user32.dll  
C:\Windows\SyChpe32\gdi32.dll
```

```
# Su hardware x86 nativo, il path sarebbe C:\Windows\SysWOW64\  
# La presenza di SyChpe32 indica esecuzione su Apple Silicon (QEMU ARM)  
# → DanaBot rileva l'ambiente non-nativo e termina (anti-sandbox)
```

Osservazione 3 Prefetch + SRP Policy Check

```
# File Prefetch creato → esecuzione confermata:  
C:\Windows\Prefetch\DANABOT.EXE-56B6F7D9.pf  
  
# Controllo Software Restriction Policy (anti-esecuzione in sandbox):  
HKCU\Software\Policies\Microsoft\Windows\Safer\CodeIdentifiers  
  
# CPU info query (anti-VM - T1082 System Information Discovery):  
HKLM\HARDWARE\DESCRIPTION\System\CentralProcessor\0
```

Il comportamento di DanaBot su FlareVM (UTM ARM) è coerente con quello rilevato nella sandbox Win11 di tria.ge: crash immediato tramite WerFault.exe e nessun traffico di rete. Questo dimostra che DanaBot include **controlli anti-VM/anti-emulazione** che lo rendono silente su ambienti non-x86 nativo.